

OPEN REDIRECTION VULNERABILITY

INTRODUCTION

Open Redirection is a common web application vulnerability that occurs when a user is redirected to an external or untrusted URL without proper validation. While often underestimated, this vulnerability can be exploited by attackers for phishing, stealing credentials, or redirecting users to malicious websites. Understanding how this flaw works and how to identify it is essential for penetration testers and web developers to protect users from trust-based attacks.

1. What is Open Redirection?

Open Redirection, also known as Unvalidated Redirects and Forwards, is a security flaw that allows attackers to redirect users to a malicious website by manipulating unvalidated parameters in the URL.

For example: `https://example.com/redirect?url=http://malicious.com`

If the application blindly redirects the user to the url parameter's value without checking its validity, an attacker can exploit it to:

- Bypass access controls
- Conduct phishing attacks
- Trick users into believing the redirection is legitimate

Such redirects undermine user trust and increase the risk of social engineering attacks.

2. What Are the Parameters to Look For?

Attackers typically look for certain query parameters or URL patterns that handle redirects. Common ones include:

- `?redirect=`
- `?url=`
- `?next=`

- ?destination=
- ?continue=
- ?return=
- ?goto=

Examples to test:

1. <https://targetsite.com/login?next=http://evil.com>
2. <https://target.com/redirect?url=https://malicious.com>

3. Impact of the Vulnerability

The impact of Open Redirection can vary depending on how it's exploited, but common consequences include:

- **Phishing attacks:** Redirecting users to fake login pages that steal credentials
- **Bypassing filters:** Used to evade URL filters by first redirecting through a trusted site
- **Trust abuse:** Users trust the domain but are redirected to malicious content
- **Session hijacking:** Combined with other attacks, it can help steal session tokens
- **Reputation damage:** Trusted domains being used for scams can reduce credibility

CONCLUSION

Open Redirection may seem like a low-risk issue at first, but when chained with other vulnerabilities, it can pose serious security risks. Attackers take advantage of user trust and poor validation logic to exploit this flaw for phishing, malware delivery, and evasion. As a cybersecurity intern, learning to detect and responsibly report open redirection vulnerabilities equips me to better protect web applications and their users. Every redirect should be validated against a whitelist or internal URL list to ensure safe navigation.